

Region Zealand receives serious criticism for lack of security measures

Date: 13-09-2023

Decision

Public Authorities

Serious Criticism

Supervision / Self-initiated Case

Basis for Processing

The Data Protection Agency has expressed serious criticism of Region Zealand's lack of security regarding broad access to personal data and for having a logging system that did not allow for visibility into which personal data a given user accessed. The Data Protection Agency received a report that employees at Region Zealand have access to patient lists across all of Region Zealand's hospitals via the front page of the Health Platform. The Data Protection Agency chose to initiate a self-initiated case to investigate the matter.

Summary

Unauthorized access to personal data by authorized users poses a significant risk that all data controllers must address. The Data Protection Agency has found in several cases that data controllers have not implemented sufficient security measures to mitigate this risk. In these cases, data controllers have claimed that they – as the only security measure – have informed users of their confidentiality obligations and the possible criminal consequences if the confidentiality obligation is violated. However, in most cases, this is not sufficient to protect the rights of the data subjects. Even in cases where users are well-informed, the Data Protection Agency receives reports of breaches of personal data security, where unauthorized use of access rights is the cause of the breach.

Enhanced Security Measures

Although the decision concerns a specific case, the Data Protection Agency must emphasize the following security measures to all data controllers:

1. Access to personal data should only be granted to a user after a documented assessment by the data controller.
2. Employees should only have access to personal data that they have a work-related need to access.
3. The data controller must reduce the risk associated with access to personal data.
4. The data controller must implement appropriate control measures.

It is the Data Protection Agency's view that the control of access rights should at a minimum consist of a verification of the work-related need at the time of granting access, ongoing monitoring based on verification that the need remains relevant, and some form of auditing thereof. If the auditing is conducted as random checks, the number and frequency of selected samples should be representative in relation to the number of possible incidents and the risk to the rights of the data subjects.

Region Zealand receives serious criticism

In the specific case, the Data Protection Agency found that there may be a need for broader access to personal data in the healthcare sector – in certain cases. However, this access should be limited to those employees who have a specific work-related need and only in the work situations where it is relevant. The need for this broader access must always be weighed against the known risk scenarios. The Data Protection Agency expressed serious criticism of Region Zealand for granting all authorized users access to patient lists containing personal data from all of the Region's hospital departments – without sufficient security measures. The Data Protection Agency further found that the Region's logging practices could not establish a connection between a lookup and the specific personal data accessed through the patient list. Therefore, the Region could not document or follow up on any potential misuse of the extensive user access to personal data. On this basis, Region Zealand had not complied with Article 32, paragraph 1 of the General Data Protection Regulation.

1. Decision

After reviewing the case, the Data Protection Agency finds grounds to express serious criticism that Region Zealand's processing of personal data has not been carried out in accordance with the rules in Article 32, paragraph 1 of the General Data Protection Regulation. Below follows a detailed review of

the case and a justification for the Data Protection Agency's decision.

2. Case Presentation

2.1. Region Zealand's Comments

The Data Protection Agency received a report that employees at Region Zealand have access to patient lists across all of Region Zealand's hospitals via the front page of the Health Platform. The patient lists contain information about, among other things, personal identification numbers, names, and action or admission diagnoses of patients, to whom the employees do not necessarily have a treatment relationship. Region Zealand has stated in the case that the patient lists can be accessed from the front page of the Health Platform and that the function has existed since the system was implemented in November 2017. The number of users at the reported time was 16,322. The patient lists are lists of patients who are admitted to the hospital departments. The patient lists are pre-set to include, among other things, name, personal identification number, and admission location, but can be expanded with additional information, e.g., diagnoses or other information, if deemed necessary. the basis of a legitimate need for such access in relation to their professional duties. The Data Protection Agency emphasizes that access to patient lists should be limited to those who require it for their specific roles in patient care and treatment.

3.1. Conclusion

The Data Protection Agency concludes that the broad access to patient lists, as described, raises significant concerns regarding compliance with data protection regulations. The agency recommends that Region Sjælland reassess the access protocols to ensure that they align with the principles of necessity and proportionality under the General Data Protection Regulation (GDPR).

4. Recommendations

The Data Protection Agency suggests that Region Sjælland implement stricter access controls to patient lists, ensuring that only authorized personnel with a legitimate need can access sensitive patient information. Furthermore, the agency advises the region to provide training for staff on data protection and the importance of maintaining patient confidentiality.

5. Follow-up

The Data Protection Agency will monitor the situation and expects Region Sjælland to report back on the measures taken to address the concerns raised in this decision. A follow-up review will be conducted within six months to assess compliance with the recommendations provided.

6. Final Remarks

The Data Protection Agency reiterates the importance of safeguarding patient data and ensuring that access to such information is strictly regulated to protect patient privacy and uphold the integrity of the healthcare system.

****Based on a considered and documented decision from the data controller.****

The user's access to personal data must reflect a necessary connection to the realization of the purpose for which the information is legally processed. The Data Protection Authority has established in several decisions on the Authority's website[2] that this connection to the purpose – for employee users – must exist as a work-related need before access is granted. It follows from Article 32, paragraph 1 of the General Data Protection Regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security that is appropriate to the risks associated with the data controller's processing of personal data.

On this basis, the data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects against these risks. The Data Protection Authority believes that the requirement for appropriate security will normally entail that the data controller continuously checks whether user accesses to systems are limited to the personal data that is necessary and relevant for the respective user. Furthermore, it is the Data Protection Authority's opinion that the requirement for appropriate security will normally involve the data controller continuously conducting random checks of the log to verify that users only access information for which they have a work-related need.

Moreover, it is the Data Protection Authority's view that the control of access rights should, at a minimum, consist of a verification of the work-related need at the time of granting access, ongoing checks based on verification that this need is still present, and some form of auditing thereof. If the auditing is conducted as random checks, the number and frequency of the selected samples must be representative in relation to the number of possible incidents and the risk to the rights of the data subjects.

The Data Protection Authority understands that the healthcare sector may generally have a need for broader access to personal data to ensure that relevant healthcare professionals have knowledge and familiarity with the patient so they can perform their work in accordance with the healthcare regulations to which they are subject. However, the Data Protection Authority must emphasize that this broader access is only for those employees for whom there is a specific work-related need and only in the work situations where this may be relevant. An abstract need should instead be handled by differentiating based on work tasks and legal or professional obligations, providing separate accesses for users to conduct searches or presenting overviews that create the necessary information.

Unauthorized access to personal data – conducted by authorized users – is a threat scenario that is not only potential but represents a real and relatively frequent occurrence that leads to breaches of personal data security. This scenario occurs repeatedly, despite a generally high level of information directed at users regarding legality and potential penalties under the Penal Code for conducting unauthorized searches.

It is the Data Protection Authority's opinion that, considering the aforementioned real threat scenarios and their realization – despite the organizational measures to counteract the risk – there should be a limitation on the immediate and universal access to list functions and created representations of personal data that go beyond the respective user's processing responsibility or are not necessary to carry out a specific task that requires such access to personal data.

Furthermore, it is the Data Protection Authority's opinion that in order to assess whether a given search has been justified or not, it is necessary to log the correlation between the specific personal data presented, sought, or visible on the screen and the user context for it.

The Data Protection Authority finds that Region Zealand – by granting access to patient lists for 16,322 users across all of the Region's hospitals – has had access to personal data that, based on the specific risk, did not constitute an appropriate level of security. Additionally, the Data Protection Authority finds that Region Zealand – by not having a log that reflected which personal data a given user had viewed – has not had appropriate technical and organizational measures that could document and follow up on any misuse of the very broad user access granted to personal data. Thus, Region Zealand has not complied with Article 32, paragraph 1 of the General Data Protection Regulation.

The Data Protection Authority therefore expresses serious criticism that Region Zealand's processing of personal data has not been conducted in accordance with the rules in Article 32, paragraph 1 of the General Data Protection Regulation. The Data Protection Authority has also given weight to the fact that the Danish Patient Safety Authority has stated that, in their assessment, there are no substantial reasons for the – outside of their own department – very broad access to patient lists in treatment contexts. And that such access would only be relevant for doctors and other professional staff with specific relevant supervisory functions.

The Data Protection Authority must emphasize that the assessment of the risk expressed in the decision should prompt Region Zealand to revise the entire access rights structure that is generally used, and that it is the Authority's expectation that the Region revises all areas where broad access is used without a specific treatment relationship or a specific documented need for access to personal data.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Including 2012-622-0004, 2014-632-0075, and 2022-423-0261.